

LoadLead — Pending Register

Read this first. Every *PARTIAL / PENDING / NOT-STARTED* item across product and security, prioritized blockers-first. Reconciled against commit `0f5588d` (the actual code, not the specs).

Each item carries: **Evidence** (where in the repo the gap shows up) · **Severity** (Critical / High / Med / Low) · **Owner** (when assigned) · **Fix** (one-line resolution). Anything marked Done is in the architecture/security docs with a file/route citation, not here.

GO-LIVE BLOCKERS (none currently open)

No production-blocking items open right now. The blockers from earlier in this stream — admin bootstrap exposure, errorHandler order, OO router gate, one-parent invariant deadlock — have all shipped to prod and are tested. See `docs/ATTESTATION_PHASE_1.md §1d` and `docs/AUDIT.md` for the closed-blocker ledger.

HIGH — security / privilege / data-integrity gaps

#	Item	Evidence	Severity	Fix
1	/api/maps/* 3 routes are public	backend/src/routes/maps.ts — no router.use(authenticate), no inline authenticate on any of POST /estimate, GET /geocode, GET /reverse-geocode. Google Maps quota is exposed to any caller; cost-DoS surface.	High	Add router.use(authenticate) to all routes; require any auth for /estimate (no role gate needed for /geocode only). 5-min fix; flagged for shipping to prod with next release.
2	STIG checklist: 38/38 controls "Not Reviewed"	docs/security/stig-checklist.md — every LL-* row's status column reads Not Reviewed. Control-coverage metric = 0% reviewed. Many controls are <i>implemented</i> (see docs/SecurityPosture.md §controls map) but no one has signed the row off.	High	Walk the 38 controls, mark each as Reviewed, NotAFinding (with evidence), or NotReviewed (with finding), NotReviewed (with reason), or leave NotReviewed (with reason). 1-2 hours of focused review.
3	Pact provider verification still uses in-process stub	backend/tests/contract/verify-provider.ts builds a stub Express app with hand-mirrored handlers. Catches <i>structural</i> drift (renamed/missing fields, wrong status codes); does NOT catch <i>semantic</i> drift (real auth path, real DDB queries, real signature service). Documented follow-up in docs/LoadLead_CrossPersona_Contract_UAT_BDD.md.	High	Wire verify-provider to use real Express app + DDE session.
4	MFA enrollment exists for admin TOTP only	backend/src/routes/auth.ts:/2fa/* — TOTP 2FA is plumbed end-to-end. No WebAuthn, no enforcement of MFA on privileged roles (CARRIER_ADMIN, OWNER_OPERATOR). STIG LL-IA-004 maps here.	High	Decide policy: (a) require MFA for all ADMIN at minimum, (b) require MFA for all ADMIN + CARRIER_ADMIN at minimum, (c) require MFA for all ADMIN + CARRIER_ADMIN + OWNER_OPERATOR at minimum. Ship WebAuthn alongside TOTP rollout = 1 session.
5	Stale Terraform state files	infra/terraform/_bootstrap/.terraform/, infra/terraform/_bootstrap/terraform.tfstate, infra/terraform/_bootstrap/terraform.tfstate.backup,	High	Add scripts to remove stale state files from infra/terraform/_bootstrap/.

	in _bootstrap/	_bootstrap/.terraform.lock.hcl — untracked, local-only, but the dir lacks a .gitignore like envs/prod/ does. Accidentally committing one of them would leak the AWS state path.		listing .terraform/, fix.
--	-------------------	---	--	---------------------------

🟡 MEDIUM — coverage / consistency gaps

#	Item	Evidence	Severity
6	correctsSignatureId has no admin UI	Field plumbed end-to-end (input + persisted + tested in backend/tests/reliability/signatureReplayProtection.test.ts) but no surface in frontend— v2/src/components/admin/AttestationLookup.tsx shows "this correction supersedes prior sig X."	Med
7	<i>UAT-CT- sign-off blank for all 7 personas*</i>	docs/UAT_CT_Checklist.md — every Tester/Date/Result cell empty. The automated @H5..@H11 pacts pass; the human ratification that the contract IS what each persona team wants is pending.	Med
8	9 of 28 critical DDB tables had PITR off pre-import	Fixed during the TF import (commit d1a3ec6) — all 28 now have PITR. The gap existed for ~weeks. Worth a calendar audit (backend/scripts/audit-pitr.sh) or a CloudWatch alarm on PITR state changes.	Med
9	Provider stub vs real Express (subset of #3)	Same root cause as #3; broken out so it counts in BOTH the security gap (no semantic verification) AND the test-coverage gap (the in-process stub artificially passes).	Med
10	CloudFront customer distro:	infra/terraform/envs/prod/cloudfront-imported.tf — customer distro has lifecycle.ignore_changes = [origin,	Med

	4 blocks ignored by TF	default_cache_behavior, ordered_cache_behavior, custom_error_response]. TF tracks identity + WAF + cert + aliases only. Drift in those 4 blocks is invisible to plan.	
11	EB env imported identity-only (151 OptionSettings ignored)	infra/terraform/envs/prod/eb-imported.tf — lifecycle.ignore_changes = [setting, version_label]. TF tracks the env exists; OptionSettings stay managed by EB console / deploy-backend.sh / .ebextensions.	Med
12	Pact deliberate-break only supports oo-web	backend/tests/contract/verify-provider.ts:DELIBERATE_BREAK switch only handles oo-web. The @H11 scenario language implies the demo should work against any persona.	Med
13	Real Express + DDB Local for verify-provider (subset of #3 + #9)	Same. Listed once more as the canonical entry.	Med

● LOW — hygiene / nice-to-have

#	Item	Evidence	Severity	Fix
14	3 test-fixture branches on	test/blocked-pr, test/jira-ref-check, verify/protection-live —	Low	git push origin --delete

	remote	intentional evidence the SCRUM-key CI gate works. Could be deleted now that the gate is documented and trusted.		test/blocked-pr test/jira-ref-check verify/protection-live if you want a cleaner branch list.
15	audit-outstanding.json overlaps this register	docs/audit-outstanding.json has 8 items (the earlier audit's leftovers). Same surface as Items #2/#7/#11-#13 here. Worth consolidating so contributors look at ONE list.	Low	Either fold audit-outstanding.json entries into this file, or replace it with a pointer to this file.
16	PactFlow free-tier 30-day trial active	The Enterprise trial auto-drops to free tier in ~30 days. Free tier handles 100 verifications/mo; workflows trigger on contract-file changes only, so this is fine. Worth a calendar reminder to confirm tier on day 31.	Low	Calendar event for 2026-07-25. Or downgrade explicitly via Settings → Plan in PactFlow now.
17	16 secondary DDB tables not in TF previously (fixed)	infra/terraform/envs/prod/imported-tables.tf — all 16 are now imported in commit d1a3ec6. Listed here as a completed item; will move out of this register on next reconciliation.	Done	n/a
18	Driver-side correctsSignatureId UX (sub of #6)	Same as #6.	Low	Same.

How this register is maintained

This file is rebuilt on every docs reconciliation pass (currently manual; future cron). The contract is:

- **No fabricated items** — every row cites a concrete file/route/test/scan output.
- **Severity is judged by blast radius, not by ease of fix.** A 5-minute fix can be High if the gap exposes a quota-DoS surface (Item #1).
- **Done items live in** `docs/Architecture_Backend.md` / `Architecture_Frontend.md` / `SecurityPosture.md` with the file citation. This register is for *not-yet-done* only.
- **Reconciled commit SHA** at the top of this file. If you read this against a later commit, some rows may be stale; re-run the reconciliation pass.

Source data

- `docs/audit-outstanding.json` — prior audit's open items (8)
- `docs/security/stig-checklist.md` — 38 LL-* controls
- `backend/src/routes/*.ts` — live route inventory (177 routes, 156 auth'd, 21 public)
- Latest compliance CI run: `gh run view 28144118496` (all green)

- This pass's reconciliation findings (new in this register)

connie-title: LoadLead — System Overview (plain language) connie-
publish: true status: Reconciled last-reconciled-against: 0f5588d
audience: investors, partners, non-engineering reviewers

LoadLead — System Overview

Status badges used throughout this doc-set:  Done ·  Partial ·  Pending ·  Not started

What LoadLead is, in one paragraph

LoadLead is a freight-matching SaaS platform that connects shippers (companies with cargo to move) to carriers (companies and individuals with trucks). It handles the full lifecycle of a freight shipment: a shipper posts a load, the system matches it to qualified carriers, a driver accepts the load, picks it up, delivers it, and a receiver confirms delivery — all with signed attestations and proof-of-delivery photos that are stored as legally binding records. Live in production at <https://loadleadapp.com> (customer-facing), <https://admin.loadleadapp.com> (internal staff), and <https://api.loadleadapp.com> (the API every persona talks to).

The five personas + platform staff

LoadLead has **five public personas** and **one internal surface**. Each runs against the same API but has a separate UI and a separate trust profile:

Persona	Who they are	Primary surface	Status
Shipper	A company posting freight to be moved	loadleadapp.com → /shipper/*	 Done
Carrier (CARRIER_ADMIN)	A trucking company managing drivers + accepting loads	loadleadapp.com → /carrier/*	 Done
Owner Operator	One-person trucking business (drives + manages own fleet)	loadleadapp.com → /owner-operator/*	 Done
Driver	An individual driver, employed by a Carrier or OO	loadleadapp.com → /driver/*	 Done
Receiver	A facility that takes delivery of inbound shipments	loadleadapp.com → /receiver/*	 Done
Platform staff (ADMIN)	LoadLead's own ops / support / fraud team	admin.loadleadapp.com (separate subdomain)	 Done

The five public personas sign up themselves via `/signup?role=<KEY>` . The internal admin surface is on a separate subdomain with stricter controls — it's not part of the public app and not a public persona.

Independence principle: Each persona is built and tested separately. They share the API but the UI flows, dashboards, and onboarding tours are persona-specific. A change made for one persona's UI cannot break another's; the Pact cross-persona contract suite (see `docs/LoadLead_CrossPersona_Contract_UAT_BDD.md`) enforces this at the API contract layer.

The load lifecycle, end-to-end

A freight shipment moves through these stages. Each stage emits a **signature** + (where applicable) **proof photos** that get locked into an append-only audit chain.

```
flowchart LR
    A[Shipper posts<br/>load] --> B[BOL_SUBMIT<br/>signed by Shipper]
    B --> C[Broadcast to<br/>matching carriers]
    C --> D[Driver / Carrier<br/>accepts offer]
    D --> E[CARRIER_ACCEPT<br/>signed by Carrier/00]
    E --> F[Dispatch:<br/>load BOOKED]
    F --> G[Driver picks up<br/>+ photo]
    G --> H[DRIVER_PICKUP<br/>signed by Driver]
    H --> I[In transit]
    I --> J[Driver delivers<br/>+ photo]
    J --> K[DRIVER_DELIVER<br/>signed by Driver]
    K --> L[Receiver verifies<br/>+ photo]
    L --> M[RECEIVER_CONFIRM<br/>signed by Receiver]
    M --> N[Chain complete:<br/>5 sigs, 3 photos]

    style B fill:#e1f5e1,stroke:#080
    style E fill:#e1f5e1,stroke:#080
    style H fill:#e1f5e1,stroke:#080
    style K fill:#e1f5e1,stroke:#080
    style M fill:#e1f5e1,stroke:#080
```

The 5 green nodes are the **attestation signatures**. Each one is:

1. Signed by an authenticated user with the right role for that stage (resolver-based; see `docs/Architecture_Backend.md §attestation`)
2. Recorded as an immutable row in `LoadLead_Signatures` (DDB conditional-write + IAM Deny + per-folder ESLint rule = three layers of append-only)
3. Mirrored to a WORM S3 bucket (`loadlead-signatures-worm-sink` , Object Lock COMPLIANCE through 2033) by a DDB-Streams Lambda within ~5 seconds
4. Bound to its proof photos via `sha256` content hash on the photo bytes

Stages 3, 4, 5 (driver pickup/deliver, receiver confirm) **require** at least one finalized proof photo before the signature is accepted. The photo bytes themselves land in `loadlead-pod-uploads-v2` (Object Lock COMPLIANCE through 2033, applied per-object at finalize time).

Live proof: The full lifecycle has been driven end-to-end against prod with real `e2e-*` accounts. See `docs/ATTESTATION_PHASE_1.md §1d` for the actual loadId, signatures, photo IDs, and the cross-tenant 403 proof.

Two layers of access control

LoadLead has **two distinct authorization layers** because the platform staff are different from the personas:

Layer 1 — UserRole (the public-persona role)

Set at signup. Determines which app/dashboard the user can reach. Cannot be self-changed.

```
SHIPPER · CARRIER_ADMIN · OWNER_OPERATOR · DRIVER · RECEIVER · ADMIN
```

ADMIN is the platform staff role — not selectable at public signup; assigned via the internal admin bootstrap (/api/setup/complete , single-use token, atomic singleton).

Layer 2 — OrgRole (the in-org role, for carrier orgs)

A Carrier organization has its own internal hierarchy. Set per-org-membership.

```
OWNER · MANAGER · DISPATCHER · ORG_DRIVER · SHIPPER_USER
```

A user can be (and often is) UserRole=CARRIER_ADMIN AND have OrgRole=DISPATCHER in a specific carrier org. Permissions are computed by the permissions matrix in backend/src/services/orgPermissions.ts — never by string-matching role names. Specifically:

- "Who can sign BOL_SUBMIT for a load?" → matrix lookup loads:create → OWNER + MANAGER + DISPATCHER + SHIPPER_USER
- "Who can sign CARRIER_ACCEPT?" → matrix lookup loads:accept → OWNER + MANAGER + DISPATCHER
- "Who can read the carrier dashboard?" → matrix lookup dashboard:read

Platform ADMIN is a **separate axis**, never conflated with org roles. A LoadLead support agent reading an org's data uses ADMIN; an OWNER of that org uses OWNER. Different code paths, different audit trails.

What's built today vs. what's pending

A reviewer's two-question checklist:

Question	Answer	Evidence
Can a real shipper post a load and have a real driver accept + deliver it on prod today?	Yes — proven E2E	scripts/e2e-attestation-prod.sh last run, docs/ATTESTATION_PHASE_1.md \$1d
Can a fraud investigator at LoadLead read every signature on a shipped load + verify the photos haven't been swapped?	Yes — proven E2E	Admin chain panel + WORM bucket Object Lock; same audit doc

What is **not built** is consolidated in docs/PendingRegister.md . The biggest user-visible gap right now is item #1 (the /api/maps/* routes are public — a quota-exhaustion risk, not a data-leak risk). The biggest invisible gap is the STIG checklist showing 38/38 controls as "Not Reviewed" even though many are actually implemented (item #2).

Where to read next

- **Investor / partner** → read this file + docs/SecurityPosture.md \$Executive Summary + docs/PendingRegister.md (in that order).
- **Engineer onboarding** → docs/Architecture_Backend.md + docs/Architecture_Frontend.md + docs/Data_API_Reference.md .

- **Security reviewer** → docs/SecurityPosture.md (full doc) + docs/security/stig-checklist.md + docs/PendingRegister.md .
- **QA / contract owner** → docs/LoadLead_CrossPersona_Contract_UAT_BDD.md + docs/UAT_CT_Checklist.md .

connie-title: LoadLead — Backend Architecture (status-tagged) connie-publish: true status: Reconciled last-reconciled-against: 0f5588d

Backend Architecture

Every subsystem carries a status badge: Done · Partial · Pending · Not started. Each Done badge cites a file/route/test. Each non-Done points at the entry in [PendingRegister.md](#) .

Stack Done

Layer	Choice	Evidence
Runtime	Node.js 22 on AWS Elastic Beanstalk (AL2023)	EB env loadlead-backend-prod, platform 64bit Amazon Linux 2023 v6.11.1 running Node.js 22
Language	TypeScript (strict)	backend/tsconfig.json
Web framework	Express 5	backend/src/index.ts
Database	DynamoDB (28 prod tables, all PAY_PER_REQUEST, all PITR)	infra/terraform/envs/prod/imported-tables.tf + main.tf
Object storage	S3 — 5 buckets, 2 WORM	infra/terraform/envs/prod/{worm-sink,pod-uploads-v2,frontend-buckets-imported}.tf
Auth	JWT in httpOnly cookies	backend/src/middleware/auth.ts
Tests	Vitest — 266 cases, 0 failures	backend/tests/ (unit + security + reliability + contract)

High-level component map Done

```
flowchart TB
    subgraph "Edge (CloudFront E38CZNP7L2DB98)"
        CF[loadleadapp.com]
    end
    subgraph "Edge (CloudFront E1RPGX7HLJI48U)"
        CFA[admin.loadleadapp.com]
    end
    subgraph "API (EB loadlead-backend-prod)"
        IDX[index.ts]
        ROUTES["routes/<br/>15 files · 177 endpoints"]
        SVC["services/<br/>36 services"]
        ROUTES --> SVC
    end
```



```

    SVC --> ATT["attestation/<br/>(signature chain)"]
end
subgraph "Data"
    DDB[("DynamoDB<br/>28 tables")]
    S3W[("S3 Object Lock<br/>signatures-worm-sink<br/>pod-uploads-v2")]
    S3F[("S3 frontend<br/>loadlead-frontend-prod<br/>loadlead-admin-prod")]
end
subgraph "Integrations"
    DIDIT[Didit IDV/KYB]
    FMCSA[FMCSA carrier lookup]
    MAPS[Google Maps]
    RESEND[Resend email]
    SES[AWS SES inbound]
end
subgraph "Async"
    DSTREAM[DDB Stream]
    LAMBDA[signatures-worm-sink Lambda]
    DSTREAM --> LAMBDA
    LAMBDA --> S3W
end

CF --> IDX
CFA --> IDX
SVC --> DDB
SVC --> S3W
SVC --> S3F
SVC --> DIDIT
SVC --> FMCSA
SVC --> MAPS
SVC --> RESEND
SES --> SVC
DDB --> DSTREAM

```

Routes Done

177 total routes across 15 files. Auth coverage: 156 / 177 = 88.1% authenticated; 21 truly public.

File	Routes	File-level auth	Notes
routes/admin.ts	23		Internal staff console
routes/attestation.ts	4		Sign + photo + chain read
routes/auth.ts	14	mixed	7 pre-auth (login/signup/etc), 7 inline-auth
routes/bol.ts	8		Bill of lading lifecycle
routes/driver.ts	25		Driver loadboard + lifecycle
routes/factoring.ts	10		Carrier factoring opt-in

routes/maps.ts	3	🟡 NONE — see PR-1	Google Maps quota exposure
routes/notifications.ts	7	✅	In-app inbox
routes/org.ts	24	✅	Org membership + IAM + dispatch
routes/ownerOperator.ts	18	✅	OO self-haul + fleet
routes/receiver.ts	6	✅	Inbound + RECEIVER_CONFIRM
routes/reference.ts	8	public (intentional)	Taxonomy lookups
routes/setup.ts	3	public (intentional)	Admin bootstrap (single-use token)
routes/shipper.ts	12	✅	Post-load + track
routes/support.ts	11	✅	Internal support inbox

The full method/path/guard table is in [Data API Reference.md](#) . Generated from `backend/src/routes/*.ts` on every reconciliation pass; the script is `docs/.build/route_inventory.json` .

Auth + session ✅ Done

flowchart LR

```

A[Browser] --HTTPS--> CF[CloudFront]
CF --> EB[Express on EB]
EB --"Set-Cookie<br/>httpOnly Secure SameSite=Lax"--> A
A --"Cookie: token=..."--> EB
EB --verify JWT--> AUTH["authenticate()<br/>middleware/auth.ts"]
AUTH --pass--> RG["requireRole / requireOrgCapability<br/>(matrix)"]
RG --pass--> H[route handler]

```

Property	Value	Evidence
Token type	JWT (HS256)	<code>backend/src/middleware/auth.ts</code>
Transport	httpOnly cookie, Secure, SameSite=Lax	<code>backend/src/middleware/auth.ts</code> issue/clear logic
Refresh	Single-token (no refresh-token rotation yet)	Limitation noted in STIG LL-SM-002 (Not Reviewed)
Logout	Cookie cleared; no server-side denylist	STIG LL-SM-003 — gap if reuse-after-logout is a threat
Auth gate	<code>router.use(authenticate)</code> at file top (11/15 files)	<code>grep router\.use\(authenticate\) in backend/src/routes/*.ts</code>
Public-by-design routes	21: 7 in <code>auth.ts</code> (signup/login/etc), 8 in <code>reference.ts</code> (taxonomy), 3 in <code>setup.ts</code>	<code>docs/.build/route_inventory.json</code>

(admin bootstrap), 3 in maps.ts (🟡 see PR-1)

Carrier-of-record resolver Done

flowchart TD

```
D[Driver row] --> Q{ownedByOperatorId<br/>set?}
Q --yes--> OO[Return<br/>OWNER_OPERATOR]
Q --no--> M[Lookup ACTIVE memberships<br/>for driver.userId]
M --> C{Any org<br/>has CARRIER<br/>capability?}
C --yes--> CO[Return<br/>CARRIER_ORG]
C --no--> N[Return null<br/>= UNAFFILIATED<br/>= no offers]
```

Three legitimate carriers-of-record:

- **Owner Operator** — driver.ownedByOperatorId set (OO self-driver: ownedByOperatorId === own operatorId)
- **Carrier organization** — first ACTIVE membership in an org with CARRIER capability
- **None** — UNAFFILIATED driver; cannot accept loads; surfaces as the "Awaiting affiliation" banner in the driver UI

Property	Status	Evidence
Resolver implementation	 Done	backend/src/services/carrierOfRecord.ts:resolveCarrierOfRecord
Used by acceptance gate	 Done	requireVerifiedCarrier() in backend/src/services/verification.ts
Used by /api/driver/affiliation (the UI signal)	 Done	backend/src/routes/driver.ts:/affiliation + tests in tests/security/driverAffiliation.test.ts
Tests	 Done	tests/unit/carrierOfRecord/resolve.test.ts + tests/unit/org/selfHaulAndOnboarding.test.ts

Verification (two gates) Done

Every driver acceptance passes through **two independent verification gates**:

1. **Authority** — the carrier-of-record's `LoadLead_Verifications` row must be `VERIFIED` (FMCSA active + KYB passed via Didit, for OO/Carrier orgs)
2. **Identity** — the driver themselves must have `idvStatus=VERIFIED` (personal IDV via Didit)

Both must clear. An OO with passed KYB who hasn't done personal IDV still can't accept loads (they're acting as their own driver).

Property	Status	Evidence
Server-side enforcement		backend/src/services/verification.ts:requireVerifiedCarrier()

Per-user IDV (not per-org duplication)	✓	User.idvStatus; Didit webhook updates the user row, not the org
Webhook HMAC verification	✓	backend/src/routes/diditWebhook (mounted in index.ts)
Webhook idempotency	✓	Conditional write on the Verifications row; double-fire is rejected
Tests	✓	tests/unit/verification/gates.test.ts, deriveStatus.test.ts

Attestation / signature chain ✓ Done — three-layer immutability

The five lifecycle signatures (B0L_SUBMIT / CARRIER_ACCEPT / DRIVER_PICKUP / DRIVER_DELIVER / RECEIVER_CONFIRM) are stored as append-only rows in LoadLead_Signatures . Three independent layers prevent mutation:

```
flowchart LR
    subgraph "Layer 1 – Authoring time"
        L1["ESLint rule denies imports  
of<br>UpdateCommand/DeleteCommand/<br>BatchWriteCommand  
in<br>services/attestation/"]
    end
    subgraph "Layer 2 – IAM"
        L2["aws-elasticbeanstalk-ec2-role<br>has inline policy:<br>Deny  
UpdateItem/DeleteItem/<br>BatchWriteItem on LoadLead_Signatures"]
    end
    subgraph "Layer 3 – DDB API"
        L3["PutItem carries<br>ConditionExpression:  
<br>attribute_not_exists(signatureId)"]
    end
    L1 -->|"impossible to author<br>an update path"| L2
    L2 -->|"even with full Put rights<br>can't update"| L3
    L3 -->|"duplicate Put on same<br>signatureId fails"| OK[Append-  
only<br>guaranteed]
```

Plus a **fourth, independent layer**:

```
flowchart LR
    SIG[LoadLead_Signatures<br>row written] --> STREAM[DDB Stream<br>NEW_IMAGE]
    STREAM --> LAMBDA[signatures-worm-sink<br>Lambda]
    LAMBDA --> S3["loadlead-signatures-worm-sink<br>S3 Object Lock  
COMPLIANCE<br>retain until 2033"]
    LAMBDA --> ALERT["alerts/integrity/* prefix<br>on any MODIFY/REMOVE event<br>(should never fire)"]
```

Property	Status	Evidence
Signature service uses only PutItem	✓	backend/src/services/attestation/signatureService.ts; ESLint config at services/attestation/.eslintrc.cjs

IAM Deny on Update/Delete/BatchWrite	✓	Applied out-of-band via scripts/attestation-bootstrap-ops.sh; TF module infra/terraform/modules/iam_signatures/
Conditional PutItem	✓	attribute_not_exists(signatureId) in signatureService.ts:recordSignature
Wrapped DDB error	✓	ConditionalCheckFailedException → AppError SIGNATURE_DUPLICATE 409
WORM sink Lambda	✓	infra/terraform/envs/prod/lambda/signatures-worm-sink/index.mjs
Object Lock COMPLIANCE on sink	✓	2555-day default retention; verified via aws s3api get-object-lock-configuration
Bucket policy denies DeleteObject	✓	infra/terraform/envs/prod/worm-sink.tf:signatures_worm_no_delete
Per-action canonical projection	✓	backend/src/services/attestation/projections/v1.ts (JCS-style sorted-key serialization)
documentHash = sha256 of canonical	✓	backend/src/services/attestation/canonicalize.ts
Resolver-based signer authZ	✓	backend/src/services/attestation/assertSignerIsLoadParty.ts
Chain READ authZ (admin		party)
correctsSignatureId field plumbed	✓	Persisted on the row; tested in tests/reliability/signatureReplayProtection.test.ts
correctsSignatureId UI	🟡	No admin surface yet — see PR-6

Proof photos (POD) ✓ Done — Object Lock per-object

```
sequenceDiagram
    participant Client
    participant API as Express
    participant DDB
    participant S3 as pod-uploads-v2
    Client->>API: POST /api/attestation/photos/upload-url<br/>{loadId, stage}
    API->>DDB: PutItem LoadLead_PodPhotos<br/>status=PENDING
    API->>Client: { photoId, s3Key, presignedURL }
    Client->>S3: PUT bytes (no client checksum)
    Note over S3: Object stored, NO lock yet
    Client->>API: POST /api/attestation/photos/:id/finalize
    API->>S3: GetObject (read bytes)
    Note over API: compute sha256
    API->>S3: PutObjectRetention<br/>COMPLIANCE + 2555d
    API->>DDB: UpdateItem<br/>status=READY, contentHash=sha256
    API->>Client: { photoId, contentHash, status:READY }
```

Property	Status	Evidence
Bucket Object Lock enabled at creation	✓	infra/terraform/envs/prod/pod-uploads-v2.tf
Bucket policy denies DeleteObject	✓	pod_uploads_v2_no_delete
Server-applied per-object retention	✓	backend/src/services/attestation/podPhotoService.ts:finalizeUpload
Synchronous finalize (server reads bytes)	✓	finalizeUpload reads + sha256s before signature accepts photold
WRONG_FINALIZER guard	✓	Tested in tests/security/podFinalizerBinding.test.ts
Idempotency on re-finalize	✓	Tested in tests/reliability/finalizeUploadIdempotency.test.ts
Bytes migrated from v1	✓	3 e2e photos migrated; v1 read-only for back-references

Integrations ✓ Done

Boot-time mode resolver picks live vs stub per `APP_ENV` (production = live, dev/staging = stub by default).

Integration	Use	Mode resolver	Status
Didit IDV/KYB	Identity + carrier authority verification	backend/src/services/integrations/didit.ts (live) + didit.stub.ts	✓
FMCSA carrier lookup	MC/DOT number validation	services/integrations/fmcsa.ts + .stub.ts	✓
Google Maps	Geocoding + distance	services/integrations/maps.ts + .stub.ts	✓
Resend	Outbound transactional email	services/integrations/email.ts	✓
AWS SES	Inbound email → support inbox	services/supportInboundService.ts	✓
Web Push	Driver push notifications	services/integrations/push.ts + .stub.ts	✓

Production-locked boot guard at `backend/src/services/integrations/bootGuard.ts` — fails closed if `APP_ENV=production` and any integration is in stub mode.

Data model — 28 DDB tables

All under Terraform management as of `d1a3ec6` . All have PITR enabled. Full schemas (hash key, range key, GSIs) in [Data API Reference.md](#) .

Group	Tables	Status
Critical (lifecycle)	Users, Loads, Offers, Drivers, Shippers, Receivers, Organizations, Memberships, BOL, Verifications, Signatures, PodPhotos	✅ Done — all 12 imported, all PITR, append-only on Signatures
Secondary (support/admin)	AdminAudit, AdminBootstrapAttempts, CarrierFactoringProfiles, FactoringOptIns, FleetInvites, Invitations, Notifications, OwnerOperators, PasswordResets, PushSubscriptions, SetupTokens, SupportInbound, SupportMessages, SupportSettings, SupportTickets, MembershipAuditLogs	✅ Done — all 16 imported, all PITR (was disabled on all 16 pre-import, fixed in d1a3ec6)

Async / event-driven layer ✅ Done

Source	Consumer	Purpose	Status
LoadLead_Signatures DDB Stream (NEW_IMAGE)	signatures-worm-sink Lambda	Mirror every signature row into the WORM S3 bucket	✅
setInterval worker (30s)	BroadcastService.rebroadcastExpiredLoads	Re-emit OPEN loads whose offers expired	✅ (in-process worker on EB; moves to EventBridge in Phase 2)
Didit webhook	routes/diditWebhook	Updates Verifications row	✅ HMAC-verified, idempotent
SES inbound	supportInboundService	Email → support ticket	✅

Observability ✅ Done — alarms wired

Alarm	Source signal	Status
worm_sink_errors	Lambda Errors metric	✅
worm_sink_throttles	Lambda Throttles metric	✅
worm_sink_iterator_age	Lambda IteratorAge metric	✅

IAM Access Analyzer	Account-wide policy scan	✅
SNS topic	loadlead-prod-ops-alerts	✅ (no subscriber yet — see PendingRegister.md)

PITR-state alarms (gap if it gets disabled out-of-band) are a follow-up in `PendingRegister.md` item #8.

connie-title: LoadLead — Frontend Architecture (status-tagged)

connie-publish: true status: Reconciled last-reconciled-against: 0f5588d

Frontend Architecture

Stack ✅ **Done**

Layer	Choice	Evidence
Build	Vite + TypeScript	frontend-v2/vite.config.ts
Framework	React 18	frontend-v2/package.json
Styling	Tailwind CSS + shadcn/ui primitives	frontend-v2/tailwind.config.ts, src/components/ui/
Routing	React Router v7	frontend-v2/src/App.tsx
State	React Query for server state; Context for auth/role/locale	src/contexts/AuthContext.tsx
Maps	Google Maps JS API	src/components/RouteMapCard.tsx
Tour	shepherd.js	src/tour/LoadLeadTour.tsx
E2E	Cypress 15.18	frontend-v2/cypress/e2e/

Build artifacts ✅ **Done — two deployable bundles**

Bundle	Built with	Deployed to	Behind
Customer	LL_BUILD=customer npm run build → dist/	s3://loadlead-frontend-prod	CloudFront E38CZNP7L2DB98 (loadleadapp.com)
Admin	LL_BUILD=admin npm run build → dist-admin/	s3://loadlead-admin-prod	CloudFront E1RPGX7HLJI48U (admin.loadleadapp.com)

The admin bundle is **on a separate subdomain** with stricter cache behavior (DefaultRootObject = `admin.html` , separate WAF, IP-allowlist-ready). Two physical builds, two physical buckets, two physical CloudFront distributions.

App structure Done

```
frontend-v2/src/
  App.tsx           # router; <RequireRole> gates per persona route
  contexts/         # AuthContext, LocaleContext
  lib/api.ts        # the ONE place every persona hits /api/*
  components/
    ui/             # shadcn primitives
    dashboard/      # CarrierDashboardView, OwnerOperatorDashboardView (shared
atoms)
  attestation/      # AttestationDialog, AttestationBlock, AttestationChain
  admin/            # AttestationLookup
  RouteMapCard.tsx  # the persona-neutral map widget
  pages/
    driver/         # 5 pages
    shipper/        # 3 pages
    carrier/        # 2 pages
    owner-operator/ # 6 pages (the 00 directory uses kebab-case)
    receiver/       # 2 pages
    admin/          # 3 pages
    bol/            # bill of lading
    settings/       # per-persona settings sub-tour
    sandbox/        # design sandbox, not in prod build
    tour/           # LoadLeadTour.tsx + per-persona tour configs
    tests/contract/ # the 6 Pact consumer pacts (one per persona)
```

Five persona apps + admin console Done

Persona	Routes	Key pages	Independence pro
Driver	/driver, /driver/history, /driver/loads/:id, /driver/analytics, /driver/verification/idv	DriverDashboard, DriverHistory, LoadDetail, DriverAnalytics, DriverVerification (new)	Pact: frontend- v2/tests/contract/dri web.pact.test.ts
Shipper	/shipper, /shipper/post, /shipper/loads/:id	ShipperDashboard, PostLoad, LoadDetail	Pact: shipper- web.pact.test.ts
Carrier (CARRIER_ADMIN)	/carrier + nested dispatch + members tabs	CarrierDashboard, MembersTab	Pact: carrier- web.pact.test.ts
Owner Operator	/owner-operator, /owner- operator/history, /owner- operator/loads/:id, /owner- operator/analytics, /owner- operator/settings,	OwnerOperatorDashboard, OwnerOperatorAnalytics, OwnerOperatorHistory, OwnerOperatorLoadDetail, OwnerOperatorSettings	Pact: oo-web.pact.tes

	/owner-operator/verification		
Receiver	/receiver, /receiver/loads/:id	ReceiverDashboard (de-fabricated), LoadDetail	Pact: receiver-web.pact.test.ts
Platform staff (ADMIN)	/admin/* (separate subdomain)	Dashboard, OrgsTable, AttestationLookup, IDV review queue	Pact: admin-console.pact.test.ts

The independence rule: each persona team can ship their own bundle without coordinating with the others, as long as the contract their consumer pact captures still verifies against the API. A change to the Shipper UI that doesn't touch `frontend-v2/src/lib/api.ts` doesn't fire the cross-persona compatibility check. A change that DOES touch the API shape triggers the can-i-deploy gate against all 6 pacts.

Key flows Done

Signup

- Landing page → role card → `/signup?role=<KEY>` → role-appropriate profile form
- 5 public personas reachable from Landing (ADMIN intentionally absent)
- Backend transactional creation with capability enforcement (`assertCapabilities()` in `orgService.ts`)
- Evidence: `src/pages/Landing.tsx` , `src/pages/Signup.tsx`

Verification (driver UX gap closed)

- `OwnerOperatorVerification.tsx` — OO two-gate (authority + identity)
- `DriverVerification.tsx` — driver two-gate (affiliation + identity), new in `978dce9` . Fills the gap where unaffiliated drivers had no obvious next step on the dashboard.

Load creation with taxonomy dropdowns

- `PostLoad.tsx` uses `Combobox` , `MultiCombobox` , `AsyncCombobox` over the reference-data API (`/api/reference/*`)
- Orthogonal type fields: mode, service-type, equipment-class, equipment-models, commodities, accessorials, hazmat-class
- Lives at `src/pages/shipper/PostLoad.tsx`

Dashboards

- Shared atoms layer at `src/components/dashboard/` ensures Carrier and OwnerOperator dashboards use the same metric primitives
- Carrier-dispatcher + Carrier-exec views (independent of OO)
- OO blended dashboard (self-haul + fleet)
- Receiver dashboard now reads real `/api/receiver/incoming` (mockData removed in `978dce9`)

Onboarding tour

- shepherd.js-based, per-persona configs (`src/tour/configs/`)
- Triggered on first dashboard render, replayable from Settings → Tour
- a11y + reduced-motion polish included

Auth-as-a-contract Done

Each persona's pact pins the authZ behavior it depends on. Pact verification runs against the broker and the can-i-deploy gate blocks the deploy if any of these flip:

Persona	Contract	Why it matters
Driver	UNAFFILIATED returns 200 { loads: [] } (NOT 403)	Dashboard relies on the empty list + the dedicated /affiliation signal to render the "Awaiting affiliation" banner; would crash on 403
Shipper	Cross-shipper read returns 404 (NOT 403)	Existence-leak protection — shipper UI distinguishes "load not found" from "forbidden"
Receiver	Cross-receiver read returns 404 (NOT 403)	Same existence-leak protection
Receiver	Confirm without signature returns 412 RECEIVER_CONFIRM_REQUIRED	UI shows the gate inline instead of generic 500
Carrier	ORG_DRIVER reading the carrier dashboard returns 403	UI routes 403 to "insufficient permission" empty state; flipping to 200-with-empty would leak revenue aggregates to drivers
Admin	Suspend without 6+ char reason returns 400	The 400 IS the audit-trail enforcement mechanism — without the reason, no row gets written

All 6 are part of the @H5..@H10 Pact features; see docs/LoadLead_CrossPersona_Contract_UAT_BDD.md .

In-app surfaces 🟡 PARTIAL

Surface	Status	Notes
Driver verification + affiliation banner	✅	shipped 978dce9
Receiver de-fabricated dashboard	✅	shipped 978dce9; stat cards "—" where backend metric doesn't exist (honest)
Admin attestation chain lookup	✅	src/components/admin/AttestationLookup.tsx
Receiver "Delivered (30d)" + "Exceptions" stat cards	🟡	Both honest "—" with "Backend metric pending" hint until a receiver-side aggregation endpoint exists
Admin view of correctsSignatureId correction chain	🟡	Field plumbed end-to-end; UI not yet rendering "this corrects X." See PR-6
Per-OO settings vs Carrier settings	✅	Separated by independence rule

Test coverage ✅ Done

Test type	Count	Where
Cypress E2E	9 specs (5 personas + a11y + cross-tenant authz + tour + smoke)	frontend-v2/cypress/e2e/
Consumer pact (contract)	6 files, 18 interactions	frontend-v2/tests/contract/
Component / unit	Minimal — most logic is in lib/api.ts (tested via pacts)	n/a
k6 load	tests/load/fan100.js — 100 concurrent load lifecycles	repo root tests/load/

Frontend type-check: 0 errors against the current main (`npx tsc --noEmit` in `frontend-v2/`).

connie-title: LoadLead — Data Model + API Reference (generated)

connie-publish: true status: Reconciled last-reconciled-against:

0f5588d generated-by: docs/.build/route_inventory.json (rebuild on every reconciliation pass)

Data Model + API Reference

Generated from the live code. Do not hand-edit — re-run the reconciliation pass to refresh.

DDB tables (28 — all PITR enabled, all PAY_PER_REQUEST, all under Terraform)

Critical / lifecycle (12)

Table	Hash key	Range key	GSIs	Notes
LoadLead_Users	userId	—	email-index	All users (5 personas + ADMIN)
LoadLead_Loads	loadId	—	status-index, shipperId-index	Lifecycle source of truth
LoadLead_Offers	offerId	—	loadId-index, driverId-index, driverId-status-index, loadId-	OFFERED → ACCEPTED/DECLINED

			driverId-index	
LoadLead_Drivers	driverId	—	userId-index	DRIVER profiles (incl. OO self-driver)
LoadLead_Receivers	receiverId	—	userId-index	Receiver facility profiles
LoadLead_Shippers	shipperId	—	userId-index	Shipper company profiles
LoadLead_Organizations	orgId	—	—	Carrier/Shipper/Receiver orgs
LoadLead_Memberships	membershipId	—	orgId-index, userId-index	User ↔ org with OrgRole
LoadLead_BOL	bolId	—	loadId-index, status-index	Bill of lading lifecycle
LoadLead_Verifications	entityId	—	status-index	Per-entity verification state (Didit-backed)
LoadLead_Signatures	signatureId	—	loadId-signedAt-index	Append-only attestation chain (IAM Deny + ESLint + ConditionExpression)
LoadLead_PodPhotos	photoId	—	loadId-index	Proof-of-delivery photo metadata (S3 Object Lock per-object)

Secondary (16)

Table	Hash key	Notes
LoadLead_AdminAudit	auditId	Privileged-action audit log
LoadLead_AdminBootstrapAttempts	attemptId	Single-use admin bootstrap tokens
LoadLead_CarrierFactoringProfiles	carrierId	Factoring partner KYB state per carrier
LoadLead_FactoringOptIns	optInId	Shipper opts a carrier into a factoring agreement
LoadLead_FleetInvites	inviteId	OO invites a driver to their fleet
LoadLead_Invitations	token	Carrier org IAM invitations
LoadLead_Notifications	notificationId	In-app inbox
LoadLead_OwnerOperators	operatorId	OO profile records
LoadLead_PasswordResets	token	Single-use reset tokens with TTL
LoadLead_PushSubscriptions	userId	Driver web-push subscriptions
LoadLead_SetupTokens	token	Admin bootstrap single-use tokens

LoadLead_SupportInbound	emailId	SES-inbound email → ticket
LoadLead_SupportMessages	messageId	Threaded support messages
LoadLead_SupportSettings	settingsId	Support team config
LoadLead_SupportTickets	ticketId	Support ticket lifecycle
LoadLead-MembershipAuditLogs	logId	Note the HYPHEN (legacy naming) — IAM membership audit trail

Storage backing — S3 buckets (5)

Bucket	Purpose	Object Lock	Public
loadlead-signatures-worm-sink	Signature audit mirror via DDB Streams Lambda	✅ COMPLIANCE 2555d, bucket policy Deny DeleteObject	Private
loadlead-pod-uploads-v2	POD photo bytes (per-object retention applied at finalize)	✅ COMPLIANCE 2555d per-object, bucket policy Deny DeleteObject	Private
loadlead-frontend-prod	Customer SPA bundle	—	Public (PublicReadGetObject, S3-website endpoint)
loadlead-admin-prod	Admin SPA bundle	—	Private (OAC-only from CloudFront E1RPGX7HLJI48U)
loadlead-terraform-state	TF remote state	—	Private (versioned + AES256-encrypted)

API endpoints (177 routes, 156 authenticated, 21 truly public)

Legend: 🗝 = file-level `router.use(authenticate)` · 🗝 = no auth · 🛡 = inline role-gate · ✨ = inline `authenticate` (file is not file-gated)

routes/admin.ts (23 routes)

Platform staff console (subdomain `admin.loadleadapp.com`).

Method	Path	Auth	Role gate
GET	/api/admin/drivers	🗝 file	🛡 file
GET	/api/admin/drivers/:driverId	🗝 file	🛡 file
POST	/api/admin/drivers/:driverId/verify	🗝 file	🛡 file
POST	/api/admin/drivers/:driverId/suspend	🗝 file	🛡 file

GET	/api/admin/shippers/admin-requests	 file	 file
POST	/api/admin/shippers/:shipperId/approve-admin	 file	 file
POST	/api/admin/shippers/:shipperId/revoke-admin	 file	 file
GET	/api/admin/loads	 file	 file
GET	/api/admin/loads/:loadId	 file	 file
PUT	/api/admin/loads/:loadId/status	 file	 file
PATCH	/api/admin/drivers/:driverId/buffer	 file	 file
GET	/api/admin/drivers/:driverId/buffer	 file	 file
GET	/api/admin/loads/:loadId/tracking	 file	 file
GET	/api/admin/fleet/feed	 file	 file
GET	/api/admin/fleet/drivers/:driverId	 file	 file
GET	/api/admin/debug/broadcast/:loadId	 file	 file
GET	/api/admin/verifications	 file	 file
POST	/api/admin/verifications/:entityId/approve	 file	 file
POST	/api/admin/verifications/:entityId/reject	 file	 file
GET	/api/admin/orgs	 file	 file
POST	/api/admin/orgs/:orgId/suspend	 file	 file
POST	/api/admin/orgs/:orgId/reinstate	 file	 file
POST	/api/admin/users/:userId/revoke-admin	 file	 file

routes/attestation.ts (4 routes)

Sign + photo + chain read. Auth via resolver-based assertSignerIsLoadParty.

Method	Path	Auth	Role gate
POST	/api/attestation/photos/upload-url	 file	—
POST	/api/attestation/photos/:photoId/finalize	 file	—
POST	/api/attestation/sign	 file	—
GET	/api/attestation/chain/:loadId	 file	—

routes/auth.ts (14 routes)

Login / signup / password / 2FA / self. 7 routes pre-auth (signup, login, forgot, reset, logout, 2fa-login); 7 routes inline-authenticate (me, change-password, 2fa setup/verify/disable/status).

Method	Path	Auth	Role gate
POST	/api/auth/signup	 public	—
POST	/api/auth/signup/carrier	 public	—
POST	/api/auth/login	 public	—
POST	/api/auth/2fa/login	 public	—
POST	/api/auth/change-password	 inline	—
POST	/api/auth/2fa/setup	 inline	—
POST	/api/auth/2fa/verify	 inline	—
POST	/api/auth/2fa/disable	 inline	—
GET	/api/auth/2fa/status	 inline	—
POST	/api/auth/logout	 public	—
GET	/api/auth/me	 inline	—
PATCH	/api/auth/me	 inline	—
POST	/api/auth/forgot-password	 public	—
POST	/api/auth/reset-password	 public	—

routes/bol.ts (8 routes)

Bill of lading lifecycle.

Method	Path	Auth	Role gate
GET	/api/bol/:bolId	 file	—
GET	/api/bol/load/:loadId	 file	—
POST	/api/bol/	 file	—
PUT	/api/bol/:bolId	 file	—
POST	/api/bol/:bolId/sign	 file	—
POST	/api/bol/:bolId/dispute	 file	—
PUT	/api/bol/:bolId/wms	 file	—
GET	/api/bol/admin/all	 file	—

routes/driver.ts (25 routes)

Driver loadboard + lifecycle. `router.use(requireRole(DRIVER, OWNER_OPERATOR, ADMIN))` — OO self-haul admitted.

Method	Path	Auth	Role gate
POST	/api/driver/profile	 file	 file
GET	/api/driver/profile	 file	 file
GET	/api/driver/verification/idv	 file	 file
POST	/api/driver/verification/idv	 file	 file
GET	/api/driver/affiliation	 file	 file
PUT	/api/driver/profile	 file	 file
POST	/api/driver/location	 file	 file
POST	/api/driver/load-status	 file	 file
GET	/api/driver/loadboard	 file	 file
GET	/api/driver/offers/:loadId	 file	 file
POST	/api/driver/offers/:loadId/accept	 file	 file
POST	/api/driver/offers/:loadId/decline	 file	 file
GET	/api/driver/active-loads	 file	 file
POST	/api/driver/headshot/upload-url	 file	 file
POST	/api/driver/loads/:loadId/pod/upload-url	 file	 file
POST	/api/driver/loads/:loadId/pickup	 file	 file
POST	/api/driver/loads/:loadId/deliver	 file	 file
POST	/api/driver/loads/:loadId/pod	 file	 file
POST	/api/driver/loads/:loadId/pod-legacy	 file	 file
POST	/api/driver/capacity/check	 file	 file
GET	/api/driver/history	 file	 file
GET	/api/driver/capacity/buffer	 file	 file
POST	/api/driver/fleet/accept-invite	 file	 file
GET	/api/driver/verification	 file	 file
POST	/api/driver/verification/submit	 file	 file

routes/factoring.ts (10 routes)

Carrier factoring opt-in workflow.

Method	Path	Auth	Role gate
--------	------	------	-----------

GET	/api/factoring/profile	🔒 file	—
POST	/api/factoring/byo	🔒 file	—
POST	/api/factoring/byo/verify	🔒 file	—
POST	/api/factoring/byo/confirm-remittance	🔒 file	—
GET	/api/factoring/byo/ready	🔒 file	—
POST	/api/factoring/partner	🔒 file	—
POST	/api/factoring/release	🔒 file	—
POST	/api/factoring/loads/:loadId/opt-in	🔒 file	—
GET	/api/factoring/loads/:loadId/payee	🔒 file	—
GET	/api/factoring/loads/:loadId/pod	🔒 file	—

routes/maps.ts (3 routes)

🟡 No auth on any route. Google Maps API key wrapper. PR-1 in PendingRegister.

Method	Path	Auth	Role gate
POST	/api/maps/estimate	🔒 public	—
GET	/api/maps/geocode	🔒 public	—
GET	/api/maps/reverse-geocode	🔒 public	—

routes/notifications.ts (7 routes)

In-app notification inbox.

Method	Path	Auth	Role gate
GET	/api/notifications/inbox	🔒 file	—
GET	/api/notifications/inbox/unread-count	🔒 file	—
POST	/api/notifications/inbox/:notificationId/read	🔒 file	—
POST	/api/notifications/inbox/read-all	🔒 file	—
GET	/api/notifications/vapid-key	🔒 file	—
POST	/api/notifications/subscribe	🔒 file	—
DELETE	/api/notifications/subscribe	🔒 file	—

routes/org.ts (25 routes)

Org membership + IAM invitations + dispatch.

Method	Path	Auth	Role gate
POST	/api/org/invitations/:token/accept	 file	 file
GET	/api/org/invitations/:token	 file	 file
POST	/api/org/	 file	 file
GET	/api/org/	 file	 file
GET	/api/org/:orgId	 file	 file
PATCH	/api/org/:orgId	 file	 file
GET	/api/org/:orgId/verification	 file	 file
POST	/api/org/:orgId/verification/submit	 file	 file
POST	/api/org/:orgId/suspend	 file	 file
POST	/api/org/:orgId/reinstate	 file	 file
GET	/api/org/:orgId/members	 file	 file
PATCH	/api/org/:orgId/members/:membershipId	 file	 file
DELETE	/api/org/:orgId/members/:membershipId	 file	 file
POST	/api/org/:orgId/members/:membershipId/suspend	 file	 file
POST	/api/org/:orgId/members/:membershipId/reinstate	 file	 file
PATCH	/api/org/:orgId/buffer	 file	 file
POST	/api/org/:orgId/drivers	 file	 file
POST	/api/org/:orgId/invitations	 file	 file
GET	/api/org/:orgId/invitations	 file	 file
DELETE	/api/org/:orgId/invitations/:token	 file	 file
POST	/api/org/invitations/:token/accept	 file	 file
GET	/api/org/:orgId/audit	 file	 file
GET	/api/org/:orgId/settings	 file	 file
GET	/api/org/:orgId/dashboard	 file	 file
POST	/api/org/loads/:loadId/dispatch	 file	 file

routes/ownerOperator.ts (18 routes)

OO self-haul + fleet management + dashboard aggregation.

Method	Path	Auth	Role gate
--------	------	------	-----------

GET	/api/ownerOperator/profile	 file	 file
POST	/api/ownerOperator/profile	 file	 file
PUT	/api/ownerOperator/profile	 file	 file
GET	/api/ownerOperator/loadboard	 file	 file
GET	/api/ownerOperator/offers/:loadId	 file	 file
POST	/api/ownerOperator/offers/:loadId/accept	 file	 file
POST	/api/ownerOperator/offers/:loadId/decline	 file	 file
GET	/api/ownerOperator/fleet	 file	 file
DELETE	/api/ownerOperator/fleet/:driverId	 file	 file
POST	/api/ownerOperator/fleet/invite	 file	 file
GET	/api/ownerOperator/history	 file	 file
GET	/api/ownerOperator/verification	 file	 file
POST	/api/ownerOperator/verification/submit	 file	 file
GET	/api/ownerOperator/verification/idv	 file	 file
POST	/api/ownerOperator/verification/idv	 file	 file
GET	/api/ownerOperator/fleet/invites	 file	 file
GET	/api/ownerOperator/settings	 file	 file
GET	/api/ownerOperator/dashboard	 file	 file

routes/receiver.ts (6 routes)

Inbound list + delivery confirmation (RECEIVER_CONFIRM signature gate).

Method	Path	Auth	Role gate
POST	/api/receiver/profile	 file	 file
GET	/api/receiver/profile	 file	 file
PUT	/api/receiver/profile	 file	 file
GET	/api/receiver/loads/:loadId	 file	 file
POST	/api/receiver/loads/:loadId/confirm	 file	 file
GET	/api/receiver/incoming	 file	 file

routes/reference.ts (8 routes)

Public taxonomy lookups (equipment, modes, services, commodities, accessorials, hazmat).

Method	Path	Auth	Role gate
GET	/api/reference/equipment-classes	 public	—
GET	/api/reference/equipment-classes/:code	 public	—
GET	/api/reference/equipment-models	 public	—
GET	/api/reference/load-modes	 public	—
GET	/api/reference/service-types	 public	—
GET	/api/reference/commodities	 public	—
GET	/api/reference/accessorials	 public	—
GET	/api/reference/hazmat-classes	 public	—

routes/setup.ts (3 routes)

Admin bootstrap (single-use token, atomic singleton). 3 routes public by design.

Method	Path	Auth	Role gate
POST	/api/setup/request	 public	—
POST	/api/setup/complete	 public	—
GET	/api/setup/status	 public	—

routes/shipper.ts (12 routes)

Post-load + track. BOL_SUBMIT signature gate on submit.

Method	Path	Auth	Role gate
POST	/api/shipper/profile	 file	 file
GET	/api/shipper/profile	 file	 file
PUT	/api/shipper/profile	 file	 file
POST	/api/shipper/admin-request	 file	 file
POST	/api/shipper/loads/draft	 file	 file
POST	/api/shipper/loads/:loadId/sign	 file	 file
POST	/api/shipper/loads/:loadId/submit	 file	 file
GET	/api/shipper/loads	 file	 file
GET	/api/shipper/loads/:loadId	 file	 file
PUT	/api/shipper/loads/:loadId	 file	 file
DELETE	/api/shipper/loads/:loadId	 file	 file

GET	/api/shipper/loads/:loadId/tracking	 file	 file
-----	-------------------------------------	--	--

routes/support.ts (11 routes)

Internal support ticket workflow.

Method	Path	Auth	Role gate
POST	/api/support/inbound	 file	 file
POST	/api/support/inbound/ses	 file	 file
GET	/api/support/tickets	 file	 file
GET	/api/support/tickets/:ticketId	 file	 file
POST	/api/support/tickets	 file	 file
PATCH	/api/support/tickets/:ticketId	 file	 file
POST	/api/support/tickets/:ticketId/messages	 file	 file
GET	/api/support/settings	 file	 file
PUT	/api/support/settings	 file	 file
GET	/api/support/monitor	 file	 file
GET	/api/support/integrations	 file	 file

Notes for reviewers

- **Auth coverage:** 156/177 = 88.1% routes authenticated.
- **Truly public:** 21 routes. Of those, 18 are legit-by-design (auth pre-login, taxonomy lookups, admin bootstrap, logout). **3 are a security gap:** /api/maps/* (see [PR-1](#)).
- **Role-gate coverage:** 120/156 = 77% of authenticated routes have an explicit role gate. The other 36 are "any authenticated user" — most are user-self routes (e.g. /api/auth/me) which are legit, but worth a focused audit when STIG LL-AC-001 review happens.
- **This file is generated** from backend/src/routes/*.ts via the route-inventory script. If the routes change, re-run the reconciliation pass to refresh.

connie-title: LoadLead — Security Posture Assessment **connie-publish:**
true status: Reconciled (CISO-grade) **last-reconciled-against:** 0f5588d
audience: CISO, board, partner security review **generated-by:** docs
reconciliation pass 2026-06-25

LoadLead — Security Posture Assessment

CISO-lens assessment, reconciled against the actual code at commit 0f5588d . No fabricated metrics; every number traces to a file, scan output, or CI run. Every implemented control is cited; every

unimplemented control is in the [Pending Register](#), not here.

Executive Summary

Overall posture: 🟢 **Production-ready with documented residual risk.** LoadLead is a freight-marketplace SaaS handling identity-verification data (Didit), proof-of-delivery photographs, and electronic signatures with legal-evidence retention requirements (ESIGN/UETA-aligned). The core data-integrity guarantees — append-only signature chain, Object Lock COMPLIANCE on legal-evidence stores, two-gate carrier verification, separated platform-staff vs persona role axes — are **implemented in code and verified in production**.

The single most important architectural decision is the **three-layer immutability** on the signature chain (ESLint ban + IAM Deny + DDB ConditionExpression, mirrored to a WORM S3 sink). This means a signature row written today cannot be modified — by any user, any service, any AWS principal — until 2033, when the Object Lock retention expires.

What is *not* yet done is operational rather than architectural: the [Pending Register](#) captures it. The most consequential open items are (1) the `/api/maps/*` routes are unauthenticated (quota-DoS surface, not a data-leak), (2) the STIG checklist's 38 controls are all "Not Reviewed" (many ARE implemented — just no one has signed the rows off), and (3) MFA exists as TOTP for ADMIN but isn't enforced for CARRIER_ADMIN / OWNER_OPERATOR.

Defensible rating basis: of the 38 LL-* STIG controls, 22 have implementation evidence visible in code or scan output (this doc cites them); 16 are partially implemented or not measured. We do not claim "compliant" until the human review pass on the checklist is signed off.

Security architecture

Authentication Implemented

Property	Implementation	Evidence
Token type	JWT (HS256) issued at login	backend/src/middleware/auth.ts
Transport	httpOnly cookie, Secure, SameSite=Lax	Cookie set in routes/auth.ts:/login
Server-side validation	Every authenticated request runs <code>authenticate()</code> middleware which verifies signature + expiry against the user row	middleware/auth.ts:authenticate
Session expiration	JWT exp claim (default 1h)	auth.ts:issueToken
Password storage	bcrypt with cost ≥ 10	services/userService.ts:registerUser
Account lockout / rate-limit	15 attempts / 15 min per-IP on <code>/api/auth/*</code>	middleware/auth.ts:authRateLimiter
2FA (TOTP)	Enroll + verify + login challenge	routes/auth.ts:/2fa/*

🟡 **Gap:** 2FA is available for any user but **enforced only for the ADMIN admin-bootstrap path**. Enforcement for `CARRIER_ADMIN` / `OWNER_OPERATOR` is open ([PR-4](#)). 🟡 **Gap:** No refresh-token rotation; logout clears cookie but doesn't denylist the JWT (token reuse-after-logout possible until natural expiry).

Authorization (two-level IAM) ✅ Implemented

Two independent role axes, never conflated:

```
flowchart TB
    subgraph "User identity"
        U[User]
    end
    subgraph "Layer 1 – UserRole (platform-wide)"
        SHIPPER · CARRIER_ADMIN · OWNER_OPERATOR · DRIVER · RECEIVER · ADMIN
    end
    subgraph "Layer 2 – OrgRole (per-org, carrier-only)"
        OWNER · MANAGER · DISPATCHER · ORG_DRIVER · SHIPPER_USER
    end
    U --> Layer1
    U --> Layer2
    Layer1 --requireRole--> H["Route handler<br/>(exact-match, no substring)"]
    Layer2 --requireOrgCapability + hasPermission--> H
```

Property	Implementation	Evidence
Exact-match role checks (no substring/regex)	<code>requireRole(...allowed: UserRole[])</code> checks <code>req.user.role === r</code>	<code>middleware/auth.ts:requireRole;</code> verified via <code>grep `grep -rE "role.*includes\(\</code>
Platform ADMIN never conflated with org roles	ADMIN is a <code>UserRole</code> ; OWNER/MANAGER/etc are <code>OrgRole</code> . Separate enums, separate middlewares (<code>requireAdmin</code> vs <code>requireOrgCapability</code>).	<code>types/index.ts:UserRole</code> vs <code>types/index.ts:OrgRole</code>
Permissions matrix (single source of truth)	<code>hasPermission(orgRole, permission)</code> looks up the matrix; no string-matching in handlers	<code>services/orgPermissions.ts</code>
Route role-gate coverage	120 / 156 authenticated routes have an explicit role gate (77%)	<code>docs/.build/route_inventory.json</code>
36 authenticated routes without explicit role gate	Most are user-self (<code>/me</code> , <code>/notifications/inbox</code> , <code>/auth/2fa/status</code>) — legitimate "any logged-in user"	Per-route audit pending in STIG LL-AC-001 review

🟢 **Strong points:**

- The DISPATCHER OrgRole was added specifically so carrier orgs could grant `loads:accept` permission to dispatch staff without forcing every booking through OWNER (which produces production-incident scars). Matrix-driven, not hard-coded.

- The "OO self-haul" case (an OO accepting a load on their own self-driver) was the prod e2e that surfaced the `requireDriver` → `requireRole(DRIVER, OWNER_OPERATOR, ADMIN)` widening — caught in CI / e2e, not in prod.

Admin surface controls 🟡 Partial

Control	Status	Evidence
Separate subdomain	✅	admin.loadleadapp.com (CloudFront E1RPGX7HLJI48U)
Separate physical bundle	✅	Built with LL_BUILD=admin, deployed to loadlead-admin-prod bucket via OAC
Bucket private + OAC-only	✅	infra/terraform/envs/prod/frontend-buckets-imported.tf:frontend_admin
TLS 1.3 minimum on admin distro	✅	cloudfront-imported.tf:admin minimum_protocol_version = "TLSv1.3_2025"
2FA enrollment for ADMIN	✅	routes/auth.ts:/2fa/setup + TOTP secret stored on User
2FA enforcement for ADMIN	🟡	Available but not gated as required for ADMIN-tier actions
IP allowlist	🟠	Not implemented; CloudFront WAF allows all IPs
Admin-bootstrap atomic singleton	✅	routes/setup.ts:/complete uses attribute_not_exists on the __admin_singleton__ row; tested in tests/security/bootstrap.race.test.ts

Per-driver IDV ✅ Implemented

Per-user IDV via Didit, stored on the User row (not duplicated per-org). The carrier-of-record gate AND the per-driver identity gate both fire on acceptance:

```
acceptOffer(driver, load):
  gate 1: resolveCarrierOfRecord(driver) → must be non-null AND VERIFIED
  gate 2: driver.user.idvStatus === VERIFIED
  if both: proceed; else: 403 with the specific reason
```

Property	Implementation	Evidence
Didit webhook HMAC-verified	✅	routes/diditWebhook reads DIDIT_WEBHOOK_SECRET, rejects bad-signature
Webhook idempotent	✅	Conditional write on the Verifications row
IDV stored on User, not per-org duplicated	✅	types/index.ts:User.idvStatus
OO self-driver inherits OO's authority but NOT identity	✅	OO must clear identity gate separately; documented in services/carrierOfRecord.ts

Attestation immutability Implemented (three-layer + WORM mirror)

The single most important data-integrity guarantee. Detailed in [Architecture Backend.md](#)
[\\$Attestation](#) . Summary of layers:

1. **Author-time** — ESLint rule in `services/attestation/.eslintrc.cjs` denies imports of `UpdateCommand / DeleteCommand / BatchWriteCommand` . Cannot author an update path.
2. **IAM** — Inline policy on `aws-elasticbeanstalk-ec2-role` denies `UpdateItem / DeleteItem / BatchWriteItem` on `LoadLead_Signatures` . Even with full Put rights, the role cannot modify a row.
3. **DDB API** — `PutItem` carries `ConditionExpression: attribute_not_exists(signatureId)` . A duplicate Put fails with `ConditionalCheckFailedException` , wrapped as `AppError SIGNATURE_DUPLICATE 409` .
4. **WORM mirror** — `LoadLead_Signatures` DDB Stream (NEW_IMAGE) → `signatures-worm-sink` Lambda → `loadlead-signatures-worm-sink` S3 bucket with **Object Lock COMPLIANCE retain-until 2033**. Even an account-root user cannot shorten retention or hard-delete before 2033. Plus bucket policy denies `s3:DeleteObject` so apparent deletes fail loudly.

Evidence (live on prod):

- `aws s3api get-object-lock-configuration --bucket loadlead-signatures-worm-sink`
→ `Mode: COMPLIANCE, Days: 2555`
- `aws s3api delete-object --version-id ...` → `AccessDenied: object protected by object lock`
- `aws s3api put-object-retention --retention Mode=COMPLIANCE,RetainUntilDate=<earlier>` → `MethodNotAllowed`

Tenant isolation Implemented (with one open class)

Property	Implementation	Evidence
Per-load ownership checks	Each <code>:loadId</code> route verifies the authenticated user is a party (shipper, assigned driver, receiver, or platform staff)	<code>services/attestation/assertSignerIsLoadParty.ts:assertCha:</code> for chain; per-route handlers for the rest
Cross-shipper / cross-receiver returns 404 (not 403)	Existence-leak protection	Contracted via <code>shipper-web</code> + <code>receiver-web</code> Pact files
Cross-tenant signer rejected	Tested live on prod: third-party user reading another tenant's chain → 403 <code>WRONG_READER</code>	<code>scripts/e2e-attestation-prod.sh \$step 12</code>
Org-scoped routes verify membership	<code>requireOrgCapability(cap)</code> middleware looks up the user's membership in the	<code>middleware/auth.ts:requireOrgCapability</code>

	org from the route params	
 IDOR systematic audit	Not done across all :id routes; per-route ownership checks are in place but not enumerated	STIG LL-AC-002 (Not Reviewed); subset of PR-2

Data protection & privacy

PII / KYC inventory

Data class	Where	Encryption	Retention	Regulatory surface
Government-ID images (license, passport)	Held by Didit — LoadLead never stores raw documents; we hold only the idvStatus enum + documentHash reference	n/a (not stored)	Didit-side	KYC/AML (FinCEN scope is light because we're not a money services business)
CDL number + license state	LoadLead_Drivers	DDB encryption at rest (AES256)	Indefinite while account active	DOT registration data, generally not PII-restricted
Personal identity (name, DOB, phone)	LoadLead_Users, LoadLead_Drivers	DDB AES256	Indefinite while account active	General PII; CCPA/GDPR-aligned with deletion flow as a follow-up
Electronic signatures	LoadLead_Signatures (immutable) + loadlead-signatures-worm-sink S3 (Object Lock 7yr)	DDB AES256 + S3 AES256	7 years (IRS business records)	ESIGN/UETA-aligned (consent capture + audit trail + immutability + retention)
Proof-of-delivery photos	LoadLead_PodPhotos (metadata) + loadlead-pod-uploads-v2 S3 (Object Lock 7yr)	DDB + S3 AES256	7 years	Same as signatures (bound by sha256 to a signature)
Support emails (inbound)	LoadLead_SupportInbound	DDB AES256	Indefinite while ticket open	Standard email confidentiality

Push subscription endpoints	LoadLead_PushSubscriptions	DDB AES256	Until user unsubscribes	Browser-issued, not PII in the strict sense
-----------------------------	----------------------------	---------------	-------------------------	---

Encryption

Layer	Status	Evidence
In transit (browser → CloudFront)	TLS 1.2+ on customer distro; TLS 1.3_2025 on admin distro	cloudfront-imported.tf
CloudFront → EB	HTTP-only (origin protocol policy); TLS terminates at CF	cloudfront-imported.tf:customer.origin
EB → DDB / S3	AWS SDK uses TLS 1.2+ to the service endpoints	AWS SDK defaults
DDB at rest	AES256 (default, AWS-managed)	All 28 tables
S3 at rest	AES256 SSE on every LoadLead bucket	worm-sink.tf, pod-uploads-v2.tf, frontend-buckets-imported.tf

Secrets handling

Property	Implementation
No secrets in code	Verified by gitleaks CI scan (latest run 28144118496:  success)
Secrets in env vars (EB OptionSettings + GH Actions secrets)	JWT_SECRET, DIDIT_API_KEY, DIDIT_WEBHOOK_SECRET, RESEND_API_KEY, GOOGLE_MAPS_API_KEY, PACT_BROKER_TOKEN
AWS credentials	OIDC via aws-actions/configure-aws-credentials@v4 — short-lived STS sessions, no stored access keys for the deploy role
Token in transcript (one-time): PACT_BROKER_TOKEN	Documented as revocable in one click ; rotation procedure in docs/PACT_CI_SETUP.md

Data retention

- **Signatures + POD photos:** 7 years (IRS business records retention). Enforced by Object Lock COMPLIANCE (not policy-resistant — even root cannot shorten).
- **User accounts:** Indefinite while active. A user-initiated deletion flow is not yet built (would need PII-erasure care given signature immutability).
- **Logs:** CloudWatch retention default (90 days for application logs); not centrally managed. STIG LL-MA-002 (Not Reviewed).

Regulatory surface

Regime	Applicability	Posture
ESIGN / UETA	Direct — every signature is a legal record	 Aligned: consent captured per-action; full audit trail in chain; immutability enforced;

		documented retention
KYC / AML	Light — we onboard carriers + verify identity but do not handle funds directly	✅ Outsourced to Dudit; LoadLead does not store raw documents
DOT / FMCSA	Direct — we verify carrier MC/DOT registration	✅ FMCSA live lookup at acceptance
CCPA / GDPR	Indirect — we have PII subjects; no EU users currently	🟡 No formal user-deletion flow yet; PII-erasure under immutable-record constraints is its own design
PCI	None (no card data handled)	n/a
SOC 2	Not pursued	🟡 Out of scope; the controls map to many SOC 2 CC-* areas if pursued later

Threat model

For a freight marketplace handling identity + financial-adjacent data, the top threats and current mitigations:

T1 — Privilege escalation across the two role axes (Critical)

Threat: A user with `UserRole=DRIVER` and `OrgRole=ORG_DRIVER` finds a way to perform `loads:accept` (a `DISPATCHER` permission) or read the carrier dashboard (a `dashboard:read` permission).

Mitigation:

- Permissions matrix is the single source of truth (`services/orgPermissions.ts`).
- No string-matching of role names anywhere; exact-match enum comparisons.
- Tested via `tests/security/dispatchSignerBinding.test.ts` (9 cases) — dispatch handler verifies signer's role on the chain, not the caller's claimed role.
- Carrier-web's Pact pins `ORG_DRIVER` → `/api/org/:orgId/dashboard` returns `403` .

Residual risk: Low. Audit trail of dispatcher-role activations would close the residual; not yet implemented (STIG LL-MA-001).

T2 — Cross-tenant IDOR (High)

Threat: An authenticated user requests `/api/shipper/loads/:id` for a load belonging to a different shipper, expecting the system to either leak data or distinguish "exists but not yours" (existence-leak).

Mitigation:

- Per-handler ownership checks; cross-shipper returns 404 (not 403) — existence-leak protected.
- Same for receivers (`tests/security/...` contracted via Pact).
- For loads viewed in the attestation chain, `assertChainReadAccess` unions per-action party `userIds` + admits ADMIN; tested in `tests/unit/attestation/chainReadAccess.test.ts` .

Residual risk: Medium. Not every `:id` route has been systematically audited. STIG LL-AC-002 review pending ([PR-2](#)).

T3 — Account takeover (Critical)

Threat: Credential stuffing / phishing → attacker logs in as a real user.

Mitigation:

- `authRateLimiter` : 15 attempts / 15 min per-IP on `/api/auth/*` .
- bcrypt password hashing.
- TOTP 2FA available (but not enforced).

Residual risk: Medium. 🟡 Per-account logout (in addition to per-IP) not implemented (STIG LL-IA-003 Not Reviewed). 🟡 MFA not enforced for privileged roles ([PR-4](#)).

T4 — Bootstrap / admin exposure (Critical)

Threat: An attacker finds the admin-bootstrap endpoint and creates an ADMIN account.

Mitigation:

- Admin bootstrap is a **single-use token** issued out-of-band (not self-serve).
- Atomic singleton guard: `routes/setup.ts:/complete` uses `attribute_not_exists` on the `__admin_singleton__` row in `LoadLead_Users` . Once one ADMIN exists, no second one can be created by this path.
- Race-condition tested in `tests/security/bootstrap.race.test.ts` (two simultaneous valid tokens — only one wins).
- Public `RequestAdminSection` REMOVED from frontend (was on landing page, fixed in `feat/admin-bootstrap-lockdown` → merged to main, audited in `docs/AUDIT.md`).

Residual risk: Low.

T5 — Signature repudiation / tampering (Critical for legal claim)

Threat: A driver claims "I didn't sign that delivery" or an attacker swaps a signature record to defraud a counterparty.

Mitigation:

- Three-layer immutability on `LoadLead_Signatures` (ESLint + IAM Deny + DDB `ConditionExpression`).
- Per-action canonical projection + `sha256` `documentHash` makes the signature payload tamper-evident.
- Proof photos bound to signatures by `sha256` of bytes (`finalizeUpload` reads bytes server-side; client cannot lie about the hash).
- WORM mirror (Object Lock COMPLIANCE) — second copy survives even if the DDB row is deleted (which itself requires bypassing layer 2).
- Tested e2e on prod via `scripts/e2e-attestation-prod.sh` with 5 real signatures + 3 real photos.

Residual risk: Very Low. Strongest control in the system.

T6 — Supply chain (Medium)

Threat: A compromised npm dependency exfiltrates secrets or alters behavior.

Mitigation:

- `npm audit` runs in CI (`compliance.yml` `deps` `job`); latest: 0 critical, 6 high, 6 moderate (12 total).
- CycloneDX SBOM generated per CI run + archived as workflow artifact.
- `package-lock.json` committed for both backend + frontend-v2; CI uses `npm ci` (lockfile-enforced).
- Pact-broker CLI + `@pact-foundation/pact` are recently added; pinned versions.

Residual risk: Medium. 6 high-severity npm advisories open (need triage); no automated lockfile audit on PRs (only on push).

T7 — Injection (SQL / NoSQL / command) (Low — by-design)

Threat: Untrusted input reaches a query, eval, or shell.

Mitigation:

- DynamoDB-only data layer — no SQL; DDB SDK uses `ExpressionAttributeValues` exclusively (no string concatenation of user input).
- Semgrep CI scan (`compliance.yml` `sast` `job`) — latest:  success, no high findings.
- No `eval()` , no `exec()` , no `child_process.spawn()` on user input — verified by grep.

Residual risk: Low. Zod schema validation is patchy across routes; STIG LL-IV-001 (Not Reviewed) flags it as a follow-up.

Security METRICS

Computed from real signals at commit `0f5588d` on 2026-06-25. Each row cites its source.

Control coverage

Metric	Value	Source
LL-* STIG controls total	38	<code>docs/security/stig-checklist.md</code> (count of LL-* rows)
LL-* controls marked <code>NotAFinding</code> (passing)	0	All 38 are <code>Not Reviewed</code>
LL-* controls marked <code>Open</code>	0	All 38 are <code>Not Reviewed</code>
LL-* controls marked <code>Not Applicable</code>	0	All 38 are <code>Not Reviewed</code>
LL-* controls with implementation evidence (cited in this doc)	~22 / 38	Indicative — formal review pending (PR-2)
CAT-I controls	8	Severity column
CAT-II controls	26	Severity column
CAT-III controls	4	Severity column
Go-live security blockers	0	All earlier blockers shipped to prod

Route authorization coverage

Metric	Value	Source
--------	-------	--------

Total /api/* routes	177	docs/.build/route_inventory.json
Routes with file-level authenticate	149 (84%)	route inventory
Routes with inline authenticate (auth.ts)	7	route inventory
Total authenticated	156 / 177 = 88.1%	sum of above
Routes truly public (intentional)	18	auth pre-login (7) + reference (8) + setup (3)
Routes truly public (unintentional gap)	3 — /api/maps/*	PR-1
Routes with explicit role gate (file or inline)	120 (77% of auth'd)	route inventory

CI scans (latest run: 28144118496)

Scan	Status	Findings	Source
gitleaks (secrets scan)	✅ success	0	gh run view 28144118496
OpenSCAP (host hardening)	✅ success	reported in artifact	compliance.yml host job
npm audit + SBOM	✅ success	0 critical, 6 high, 6 moderate, 12 total	cd backend && npm audit --json
Semgrep SAST	✅ success	reported in SARIF (uploaded to Code Scanning)	compliance.yml sast job
Prowler CIS AWS	⚪ skipped	—	configured but not gated; would re-enable when test account exists

Test coverage (security-relevant)

Suite	Count	Source
Unit tests (general)	30 files / 223 cases	find backend/tests/unit -name "*.test.ts"
SEC system tests	4 files / 20 cases	tests/security/ (bootstrap.race + dispatchSignerBinding + podFinalizerBinding + driverAffiliation)
REL system tests	3 files / 15 cases	tests/reliability/ (finalizeUploadIdempotency + signatureReplayProtection + errorHandlerDoubleResponse)

Cypress E2E (incl a11y + cross-tenant authz)	9 specs	frontend-v2/cypress/e2e/
Contract tests (Pact, cross-persona)	6 consumer pacts / 18 interactions	frontend-v2/tests/contract/
Total	266 backend tests, 0 failing	npx vitest run

Data-store hardening

Property	Value	Source
DDB tables total	28 (all under TF)	tofu state list in envs/prod/
DDB PITR enabled	28 / 28 = 100%	aws dynamodb describe-continuous-backups per table
S3 buckets with Object Lock COMPLIANCE	2 — loadlead-signatures-worm-sink, loadlead-pod-uploads-v2	aws s3api get-object-lock-configuration
S3 buckets with delete-denying policy	2 — same as above	bucket policies in TF
Encryption at rest (SSE)	28 DDB tables + 5 S3 buckets = 33 / 33 stores	TF configs

MFA / privileged surface

Metric	Value	Source
MFA enrollment endpoints (TOTP)	available for all users	routes/auth.ts:/2fa/*
MFA enforced for ADMIN-tier actions	🟡 Not yet measured (PR-4)	n/a
Admin subdomain isolated	✅ admin.loadleadapp.com separate CF distro	cloudfront-imported.tf
Admin IP allowlist	🟡 Not implemented	n/a
Admin bundle private bucket (OAC-only)	✅	frontend-buckets-imported.tf:frontend_admin

Risk register

Ordered by priority. Each row has the same shape as [PendingRegister.md](#) ; they cross-reference.

ID	Description	Component	Severity	Likelihood	Status
----	-------------	-----------	----------	------------	--------

SEC-R-001	/api/maps/* 3 routes lack auth → Google Maps quota cost-DoS surface	routes/maps.ts	High	Medium (must be discovered)	Open
SEC-R-002	38 STIG controls "Not Reviewed" — coverage cannot be claimed without sign-off	docs/security/stig-checklist.md	High	n/a (visibility)	Open
SEC-R-003	MFA not enforced for ADMIN / CARRIER_ADMIN / OO; available but optional	routes/auth.ts	High	Low (no public phishing campaign observed)	Open
SEC-R-004	Provider verification uses in-process stub, not real Express	backend/tests/contract/verify-provider.ts	High (test-coverage gap)	n/a	Open
SEC-R-005	TF state files in _bootstrap/ could leak	infra/terraform/_bootstrap/	High	Very low (untracked, never committed)	Open
SEC-R-006	Per-account lockout not in place (per-IP only)	middleware/auth.ts:authRateLimiter	Med	Low (credential stuffing visible in IP limit)	Open
SEC-R-007	Logout doesn't denylist the JWT; reuse-after-logout possible until natural expiry	routes/auth.ts:/logout	Med	Low (1h TTL bounds the window)	Open
SEC-R-008	6 high-severity npm advisories open	npm audit	Med	Low (no known active exploit in our usage)	Open

SEC-R-009	Zod validation patchy across routes	routes/*.ts	Med	Low (DDB itself rejects most malformed shapes)	Open
SEC-R-010	No PITR-state drift alarm; manual re-enable depends on noticing	per-table	Med	Very low (PITR is sticky)	Open
SEC-R-011	IP allowlist on admin subdomain not implemented	CloudFront WAF	Med	Low (admin bundle is OAC-only, admin auth requires JWT + 2FA-available)	Open
SEC-R-012	No central log retention / SIEM	CloudWatch	Low	n/a (visibility)	Open

Total open: 12 risks. **Critical:** 0. **High:** 5. **Medium:** 6. **Low:** 1.

Top risks right now (one-slide callout)

For a director-of-cybersecurity briefing. Each is one-line evidence + one-line fix.

1. 🟡 **/api/maps/* is unauthenticated** (backend/src/routes/maps.ts — no router.use(authenticate)). → Add the line. 5-min fix.
2. 🟡 **STIG checklist 0/38 controls reviewed** (docs/security/stig-checklist.md). → 3-hr sign-off pass.
3. 🟡 **MFA enrollment exists but no enforcement** (routes/auth.ts:/2fa/* — anyone can opt out). → Policy decision + gate.
4. 🟡 **Provider verification on the in-process stub, not real Express** (backend/tests/contract/verify-provider.ts). → Wire real-app + DDB Local; documented follow-up.
5. 🟢 **No prod blockers open** — every earlier blocker has shipped and is verified e2e (see docs/ATTESTATION_PHASE_1.md §1d).

Remediation roadmap

Tied to the metrics so progress is measurable. Sequenced by blocking-first.

Sprint 1 (this/next week)

- ☐ **SEC-R-001** Add `router.use(authenticate)` to `routes/maps.ts`. Re-deploy backend. Verify via `curl -i https://api.loadleadapp.com/api/maps/geocode?address=test` → 401. (5 min)
- ☐ **SEC-R-005** Add `.gitignore` to `infra/terraform/_bootstrap/`. (5 min)

Sprint 2 (next 2 weeks)

- ☐ **SEC-R-002** Walk 38 STIG controls, mark each `NotAFinding` (with evidence path) / `Open` (with finding) / `NA`. Target: 100% reviewed. (3 hrs)
- ☐ **SEC-R-003** MFA enforcement policy decision: enforce TOTP for ADMIN AND CARRIER_ADMIN; OO is opt-in. Add `requireMfa` middleware on `/api/admin/*` and on org-mutating routes. (1 day)
- ☐ **SEC-R-008** Triage 6 high-severity npm advisories. (2 hrs)

Sprint 3 (within month)

- ☐ **SEC-R-004** Replace verify-provider stub with real Express + DDB Local. (1 session)
- ☐ **SEC-R-006** Add per-account lockout to `authRateLimiter`. (½ day)
- ☐ **SEC-R-007** Refresh-token rotation + denylist on logout. (1 day)
- ☐ **SEC-R-010** AWS Config rule for PITR-state on `LoadLead_*` tables. (½ day)

Quarter (Q3 candidates)

- ☐ **SEC-R-011** Admin IP allowlist via CloudFront WAF.
- ☐ **SEC-R-012** Central CloudWatch log retention + SIEM (or skip if SOC-2 not pursued).
- ☐ **SEC-R-009** Zod schema rollout across top-20 highest-traffic routes.

Data flow + trust boundaries

```

flowchart TB
    subgraph "PUBLIC INTERNET"
        U1[Public user<br/>UserRole=any]
        U2[Internal staff<br/>UserRole=ADMIN]
    end

    subgraph "EDGE – TLS 1.2+/1.3"
        CF1["loadleadapp.com<br/>CloudFront E38CZNP7L2DB98<br/>WAF: CreatedByCloudFront"]
        CF2["admin.loadleadapp.com<br/>CloudFront E1RPGX7HLJI48U<br/>WAF: CreatedByCloudFront<br/>TLS 1.3_2025 minimum"]
    end

    subgraph "API TIER – VPC default"
        EB["Express on EB<br/>aws-elasticbeanstalk-ec2-role<br/>(Deny Update/Delete on Signatures)"]
        MW["middleware/auth.ts<br/>JWT verify + requireRole + <br/>requireOrgCapability"]
    end

    subgraph "DATA TIER – IAM-scoped"

```

```

DDB["28 DDB tables<br/>AES256, Pitr"]
S3W["S3 WORM<br/>Object Lock COMPLIANCE"]
S3F["S3 frontend<br/>OAC for admin,<br/>website for customer"]
end

subgraph "THIRD-PARTY"
  DIDIT["Didit IDV/KYB<br/>(webhook HMAC verified)"]
  FMCSA["FMCSA carrier registry"]
  MAPS["Google Maps API"]
  RESEND["Resend email"]
end

U1 -- HTTPS --> CF1
U2 -- HTTPS + IDV bypass NOT implemented (🟡 SEC-R-011) --> CF2
CF1 -- HTTP origin --> EB
CF2 -- HTTPS to admin bundle bucket via OAC --> S3F
EB --> MW
MW -. authZ-checked .-> DDB
MW -. signature finalize .-> S3W
EB -. outbound calls .-> DIDIT
EB -. outbound calls .-> FMCSA
EB -. outbound calls --no-auth-on-our-side (🟡 SEC-R-001) .-> MAPS
EB -. outbound calls .-> RESEND
DIDIT -. webhook (HMAC) .-> EB

style U2 fill:#fffacd
style CF2 fill:#fffacd
style S3W fill:#e1f5e1,stroke:#080,stroke-width:3px
style MW fill:#cde,stroke:#048

```

Trust boundaries:

- **Public ↔ Edge:** TLS-terminated. CloudFront enforces SSL min + headers. WAF default rules.
- **Edge ↔ API:** HTTP origin (CF terminates TLS). Origin protocol is `http-only` — acceptable because CF→EB stays in AWS network.
- **API ↔ Data:** IAM-scoped. EB instance role has `Deny UpdateItem/DeleteItem/BatchWriteItem` on `LoadLead_Signatures` plus `s3:DeleteObject/DeleteObjectVersion` denied on both WORM buckets.
- **API ↔ Third-party:** Outbound only (except Didit webhook). Maps is 🟡 a gap — see SEC-R-001.

This doc is reconciled against the actual code at commit `0f5588d` and re-generated on each reconciliation pass. Anything claimed Done is cited; anything Pending is in [PendingRegister.md](#). No fabricated metrics.